UNIVERSITE LIBRE
DE BRUXELLES

ANTI-PATTERNS WHEN DESIGNING ENTERPRISE SYSTEMS (COMMON MISTAKES)

Ch. Cuvelliez – Feb 11

ANTI-PATTERNS

AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an ‘on-prem’ solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **Quantum Cryptography: should I take care of it (now)**

ANTI-PATTERNS

INTRODUCTION

'Anti-pattern' : any repeated (but ineffective) solution to a common problem

- **Interconnected systems:** Computer systems rarely operate in isolation; they connect to networks and other systems.

- **Trust levels vary:** You may trust some connected networks/systems more than others; their owners may not trust yours.

ANTI-PATTERNS

AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an ‘on-prem’ solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **Quantum Cryptography: should I take care of it (now)**

ANTI-PATTERNS

BROWSE-UP FOR ADMINISTRATION

When administration of a system is performed from a device which is less trusted than the system being administered.

- **An end user device used by an administrator can be one of the easiest paths into the target system**, even if access is via a 'bastion host' or ‘jump box.
- **Bastion host misconception**: Commonly believed to "inject trust" into untrusted admin devices, providing confidence in administrator actions.
- **Reality:** Bastions only enable monitoring/logging and limit exposed protocols; they don't verify user identity.
- **Limitations:**
  - Compromised credentials on less-trusted devices remain exploitable.
  - Even with 2FA, malware can session hijack RDP/shell connections (like online banking attacks).
  - Attacker capability: Once inside bastion, attackers control the session and perform actions on behalf of legitimate admins

A jump host (also called a jump server) and bastion host : hardened intermediary servers to provide secure, controlled access to internal systems without exposing them directly to external networks.

Core Purpose

- **Acts as a secure gateway**: Admin → Jump Server → Internal Systems (i.e. FW/WAF/APP/DB Management Interfaces).
- **Reduces attack surface** — only one public-facing entry point instead of exposing all internal servers

Key Features

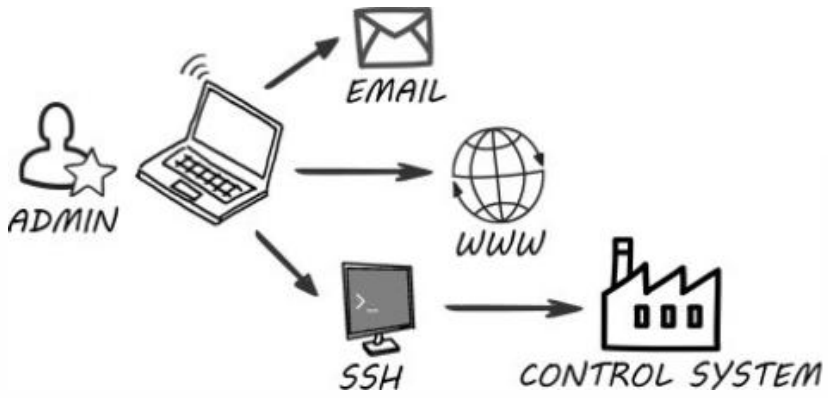
- **Strong authentication:** MFA, SSH keys, no password logins.
- **Session monitoring**: Logs all commands for audit/incident response.
- **Network positioning:** Sits in DMZ or dedicated segment between untrusted (internet) and trusted (internal) networks.

ANTI-PATTERNS

BROWSE-UP' FOR ADMINISTRATION

How Identify

- **Direct indicator**: Administration via remote desktop/shell from devices in **less trusted systems**.
- **Third-party risk**: Outsourcing/remote support where vendors use RDP/shell to access your network, but you have **less confidence** in their device integrity than yours.
- **Mixed-use danger**: Admins using RDP/shell for management from the **same device/context** used for web browsing or external email (inherently untrusted).



How to fix

- **Better approach: "**Browse-down" administration — always use high-integrity devices (trusted admin workstations) for production system management**.**
- **Device hygiene:** Admin devices must avoid web browsing and external email to maintain trust (these activities introduce malware risk).
- **If the same device is used:**
  - **Windows**: Use **different user accounts** — "admin.user" (no browser) vs "personal.user" (browser/email).
  - **Browser**: Run browser in **sandbox** (Sandboxie, Windows Sandbox) or **VM** (admin VM → no internet).
  - **Linux**: Separate **user sessions** or **containers** (admin user can't access browser files).
  - **Key**: Malware from web/email **cannot reach** your admin session because they're **isolated contexts**.

ANTI-PATTERNS

AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an ‘on-prem’ solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **Quantum Cryptography: should I take care of it (now)**

ANTI-PATTERNS

MANAGEMENT BYPASS

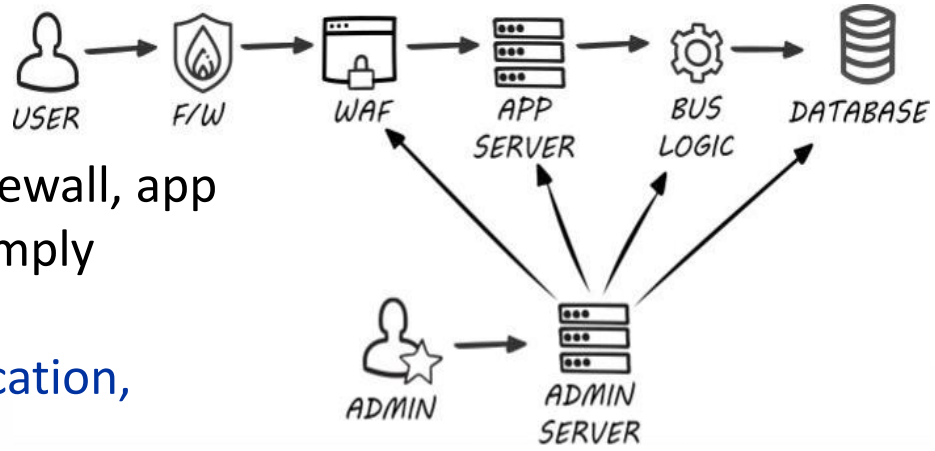
When layered defences in a network data plane can be short-cut via the management plane.

- **Data plane vs. management plane:** In system architectures, this mirrors splitting data processing from control/management functions
- **Separate management from user communications** = Best practice to isolate management traffic from normal data flows on networks.
- **Common network controls:** Firewalls/VLANs often segregate these but focus stays on data plane protection.
- **Defence-in-depth oversight**: Mistake to apply layered security only to data plane, neglecting management plane. If management plane is weaker, attackers exploit it to reach 'crown jewels' (critical assets) faster than via data plane.

ANTI-PATTERNS

MANAGEMENT BYPASS

How to identify this anti-pattern/How to improve



- All your system components (e.g., firewall, web application firewall, app servers, databases) have **admin or management interfaces** simply plugged into **one common management switch**, then:
  1. There's **no segmentation** between layers (network, application, database).
  2. If one device (say the app server) is compromised, the attacker can often **pivot sideways** and control higher-privileged devices (firewall, database) via that same management network.
  3. Essentially, your security layers collapse because they share the **same flat management network**.

ANTI-PATTERNS

MANAGEMENT BYPASS

How to identify this anti-pattern/How to improve

- Build similar layered defences into management planes to those you have in data planes.
  If there is a layered security for operational traffic (firewalls, WAFs, network segmentation), **apply the same principle to the management network**.

  Example:
  - The **database admin interfaces** should only be reachable from **database management segments**.
  - The **app server management interfaces** should only be available within the **application management zone**, and so on.
  - So, each "plane" — data and management — should have **its own defense layers and trust boundaries**.

TRUSTED BASTION → FW-MGMT ZONE → WAF-MGMT ZONE → APP-MGMT → BUS/DB-MGMT

↑ Admin connects here first (one public IP)

ANTI-PATTERNS

MANAGEMENT BYPASS

How to identify this anti-pattern/How to improve

Best practices:

- **Manage from higher to lower trust devices:**
  An admin must manage systems from **a secure, trusted "jump server" or bastion in a high-trust zone — and only access lower-trust networks (e.g., production apps, databases) through controlled paths.**
- **Different credentials per layer:**
  Use **distinct admin accounts and credentials for each layer** (firewall, app servers, databases). This prevents an attacker from reusing stolen credentials to move laterally between systems.
- **Restrict communication between data and management planes:**
  The devices that handle production data should **not reach into the management network**, and vice versa. This limits exposure — if the data plane is compromised, attackers can't reach the management tools.

A **jump host** (also called a **jump server**) and **bastion host** are hardened intermediary servers used to provide secure, controlled access to internal systems without exposing them directly to external networks

Aspect	Bastion Host	Jump Server
Location	Sits in **DMZ/perimeter** — guards external access	Lives **inside private network** — enables internal segmentation
Primary Role	Single entry point from untrusted internet	"Bridge" between internal network zones

ANTI-PATTERNS

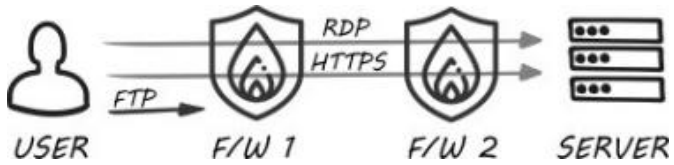
AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an 'on-prem' solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **Quantum Cryptography: should I take care of it (now)**

ANTI-PATTERNS

BACK-TO-BACK FIREWALLS

When the same controls are implemented by two firewalls in series, sometimes from different manufacturers.



Common myth:
Doubling firewalls (same controls) and using different vendors boosts security by avoiding shared vulnerabilities.
Reality: Adds cost, complexity, maintenance with little/no benefit in practice

Why ? **Redundant firewalls** at the same OSI layer (e.g., two L3/4 firewalls in series) as pointless duplication
Layer 3/4 firewalls filter traffic based on IP addresses, ports, and protocols — a straightforward "allow/deny" job: oth do **identical work**. If FW1 blocks SSH (port 22), FW2 blocks the same SSH — no additional threats are caught.

Internet → FW1 (L3/4) → FW2 (L3/4) → Internal Network
↓ blocks port 22 **↓ blocks port 22**

ANTI-PATTERNS

BACK-TO-BACK FIREWALLS

What kind of vulnerability can we find in a Firewall

- **Single firewall vulnerabilities exist** (as with most systems), but they're rare for core packet-processing functions.
- **Typical exploits target management interfaces**, not TCP/IP header processing for code execution.
- **Key defense**: Never expose management interfaces to untrusted networks.
- **Data plane vulnerabilities**: Even if firewall packet-processing flaws exist, swift patching forces attackers to use **zero-day exploits** (unknown, unpatched).
- **Defense-in-depth**: Single firewall breach shouldn't compromise critical systems — requires **multiple failures**.
- **Two zero-days unrealistic**: Needing simultaneous zero-days in both firewalls exceeds threat models for most organizations.

ANTI-PATTERNS

BACK-TO-BACK FIREWALLS

When It Makes Sense (Rare Cases)

- **Different layers**: L3/4 FW → WAF (app-layer) → **complementary**, not redundant.
- **Different roles**: Perimeter FW → Internal segmentation FW = proper defense-in-depth.
- Acts as a contract enforcement point between two connecting entities (e.g., organizations).
  - Each party manages their own firewall to enforce agreed subnet/protocol rules, ensuring mutual compliance.

In General

- **Quality over quantity**: One well-maintained, well-configured firewall outperforms two poorly managed ones.
- **Protect management interfaces**: Avoid exposing them to untrusted networks; properly manage associated credentials.
- **Keep policies simple**: Reduces risk of configuration errors.
- **Use configuration management tools**: Ensures known correct configs, detects deviations (indicating compromise or procedural failures).

Configuration management tools: automate tracking, enforcing, and auditing device settings (firewalls, switches, servers) to maintain security baselines and detect unauthorized changes

- **Baseline enforcement**: Define "golden" configs; auto-deploy/push to devices.
- **Change detection**: Monitor for drift (deviations); alert on unauthorized modifications.
- **Version control**: Track who/when/what changed; rollback if needed.
- **Compliance checks**: Validate against CIS, NIST, or custom policies.

ANTI-PATTERNS

AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an ‘on-prem’ solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **Quantum Cryptography: should I take care of it (now)**

ANTI-PATTERNS

BUILDING AN 'ON-PREM' SOLUTION IN THE CLOUD

When you build - in the public cloud - the solution you would have built in your own data centres (lift and shift)

:

- **Common cloud mistake:** Organizations lift-and-shift on-premises architectures directly onto public cloud IaaS without rethinking design.
- **Retained problems:** Same operational issues persist (patching OS/software, high maintenance overheads).
- **Missed cloud benefits:** Fail to leverage auto-scaling and native cloud elasticity features.

ANTI-PATTERNS

BUILDING AN 'ON-PREM' SOLUTION IN THE CLOUD

Typical signs

- **Database engines, file stores, load balancers, security appliances running on compute instances (VMs/EC2) instead of managed cloud services:** e.g. Running MySQL on VMs/EC2 mimics physical servers.
- **Separate dev/test/staging/prod environments running 24/7 (missing auto-scaling/shutdown policies):** Always-on servers to avoid downtime (no dynamic scaling).
- **Virtual appliances without cloud-native evaluation= On-prem thinking**: Deploy vendor VM images (NGINX VM, firewall VM) as if on VMware.

Root cause: Teams default to "what we know" (VM sprawl) instead of asking "what's the cloud-native equivalent?" — retaining datacenter pains while paying cloud premiums

ANTI-PATTERNS

AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an 'on-prem' solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **Quantum Cryptography: should I take care of it (now)**

ANTI-PATTERNS

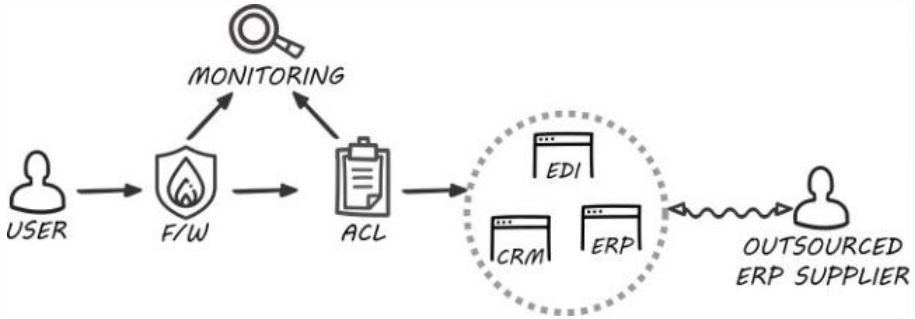
UNCONTROLLED AND UNOBSERVED THIRD PARTY ACCESS

When a third party has unfettered remote access for administrative or operational purposes, without any constraints or monitoring in place.

- **Outsourcing support is common:** Many organizations delegate some/all system support to third parties.
- **Not inherently bad:** Can work well if risks are properly understood and managed.
- **Key dependency:** You're reliant on the third party's staff, processes, and technology for system security.
- **Third-party access method:** Administering systems remotely via bastion host (internet with IP allow listing or private network) - c**ommon issue = Insufficient controls to limit operations through the bastion host.**
- **Risk:** Compromised bastion/third-party device grants attackers broad access to connected systems.

Example scenario:
Niche technology with specialist vendor support contract requiring remote access to only that specific component.

If you provided a bastion host with access to an internal network (and relied on **their** processes to only access the component they supported, rather than technically enforcing that process), then a breach of vendor's systems or bastion host enables attackers to access **far more** than intended, causing excessive damage.



ANTI-PATTERNS

UNCONTROLLED AND UNOBSERVED THIRD PARTY ACCESS

When a third party has unfettered remote access for administrative or operational purposes, without any constraints or monitoring in place.

- **A better approach: a good contract, constrained access and a thorough audit trail**
- **Vendor selection**: Choose third parties carefully with contracts specifying required controls for people, processes, and technology.
- **Constrained access**: Apply least privilege — grant remote/authenticated users access **only** to systems they need.
- **Audit requirements**: Ensure full audit trails for incident response/protective monitoring, including which commands each third-party user executed
- **Lateral movement prevention**: Ask suppliers how they stop attackers pivoting between their other clients and your systems.
- **Strong authentication**: Require MFA for remote support staff; ban credential sharing to track individual actions during breaches.
- **Isolation**: Provide separate, isolated access systems for different third parties.
- **Just-in-time access**: Enable remote admin access only for active support tickets (JIT administration).

ANTI-PATTERNS

SOLARWIND – ORION CASE STUDY (3RD PARTY ACCESS)

SEC lawsuit: U.S. SEC filed formal complaint against SolarWinds and its CISO over the attack where hackers modified Orion network management software from inside SolarWinds' systems, distributed tainted versions to clients, enabling free network access.

- **Attack impact:** 18,000 clients (including U.S. agencies) compromised; hackers entered client networks via legitimate-looking Orion updates; Akamai CDN used for distribution but breach originated internally**.**

- **Security culture failure:** Investigation revealed unimaginable lack of security culture, deficiencies, negligence, and bad faith; internal audits showed only 40% NIST controls implemented (60% missing) despite public claims.

- **Known deficiencies (internal assessments):**
  - Software lifecycle security management.
  - Password management.
  - IT resource access controls.

Reference:https://www.lemonde.fr/blog/binaire/2024/03/15/quand-le-responsable-de-la-securite-informatique-doit-vraiment-aller-en-prison/

ANTI-PATTERNS

SOLARWIND – ORION CASE STUDY (3RD PARTY ACCESS)

Secure development failures.

- Orion base software developed **without security framework**; 2018 plan for secure practices (training, pilots, quarterly rollout) never materialized but Solarwind continued false claims of secure methods.

Password policy hypocrisy:

- **Stated**: 90-day rotation, min length, complex chars — **not enforced** across systems/apps/DBs for years.
- **Issues**: Default "password" persisted on certain systems + shared SQL creds + plaintext creds on public web server+ Akamai account password exposed online for CDN (not even used by hackers).
- **Employees flagged this to IT leadership:** critical systems audited but gaps unaddressed.

Access management deficiencies (2017-2020):

- **Routine over-provisioning:** Employees got excessive system access beyond job roles; admin rights given unnecessarily (No RBAC)
- **VPN flaws: Any non-SolarWinds machine could have access to VPN, so DLP is bypassed.**
- **2018 engineer warning:** VPN allowed attacker network access, code upload/storage; ignored.

Ignored warnings:

- **Multiple employees/engineers raised alarms (2017-2020);** management aware but silent but IPO of Solarwind on Oct 2018 without disclosing risks (SEC fraud basis).

ANTI-PATTERNS

SOLARWIND – ORION CASE STUDY (3RD PARTY ACCESS)

Attack execution:

- **VPN entry (Jan 2019-Nov 2020) via stolen creds/non-company machines**.
- **Free movement dev/prod (no segmentation);** hacker disabled AV via excessive admin rights.
- **Exfiltrated 7M key staff emails** + source code; tested innocuous code (Feb 2020).
- **Inserted malicious code in 3 Orion products**; distributed via build pipeline.

Post-breach denial:

- Ignored client alerts about SolarWinds systems compromised (clients saw that)
- Claimed hackers already in client networks or State attack..

SEC fraud rationale:

- Management knew negligence level made attack predictable+ lied in website, press releases, podcasts, blogs about security practices;
- Failed to disclose to investors pre-IPO.

Whistleblower failure:

- Numerous internal alerts ignored; suggests need for mandated external reporting procedures.

Key lesson:

- Don't trust vendor security claims; perform due diligence (on-site interviews); SolarWinds lied knowingly about passoire-level security.

ANTI-PATTERNS

AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an 'on-prem' solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **Quantum Cryptography: should I take care of it (now)**

ANTI-PATTERNS

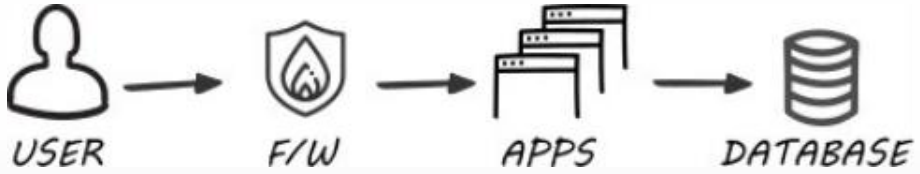
THE UN-PATCHABLE SYSTEM

When a system cannot be patched due to it needing to remain operational 24/7.

- **24/7 systems challenge:** Lack of planning can make security patching impossible without extended downtime (hours/days).
- **Downtime dilemma:** Large maintenance windows become unacceptable for critical systems.
- **Patch debt cycle:** Deferring patches accumulates massive backlogs; applying them all at once becomes too risky.
- **Un-patchable trap:** System becomes virtually impossible to secure through a vicious cycle of deferred maintenance.

Identifying unpatchable systems anti-pattern:

- **Lack of redundancy:** Architectures without failover/high availability prevent phased upgrades (can't patch one component while others run).
- **No representative environments:** Missing dev/test/reference systems (or inability to spin them up quickly) erodes confidence in patching.
- **Stability fear:** Without identical non-prod systems, owners avoid patching production to prevent unexpected disruptions.



ANTI-PATTERNS

THE UN-PATCHABLE SYSTEM

Better Approach

- **Design** systems for easy maintenance ("little and often" patching).
- **Phased patching:** Architect for incremental updates without full operational disruption (requires redundancy).
- **Cost trade-off:** Higher upfront infrastructure costs offset by:
  - Fewer/shorter outages.
  - Lower compromise risk (avoids expensive incident response).

ANTI-PATTERNS

AGENDA

- **Definition**
- **Browse up**
- **Mananagement bypass**
- **Back to Back firewalls**
- **Building an 'on-prem' solution in the cloud**
- **Uncontrolled and unobserved third party access**
- **The un-patchable system**
- **The Post-Quantum Cryptography**

ANTI-PATTERNS

IS QUANTUM CRYPTOGRAPHY A REAL PROBLEM (NOW AND TOMORROW)

How to incorporate quantum safety into existing risk management frameworks

- **By assessing the 'Migration Priority' based on the 'Quantum Risk' and 'Migration Time'**

- **Quantum Risk is based on three parameters:**
  - **Shelf Life of Protected Data:** How long the data remains sensitive.
  - **Exposure:** The extent to which data is accessible to potential attackers.
  - **Severity:** The business impact of a potential compromise

- **Migration Time is based on the complexity and timeline required to achieve Quantum Safety**
  - **Solution Availability**: Maturity of PQC standards, and their general availability in products and services.
  - **Execution Cost:** The effort, cost, and complexity of implementing the quantum-safe solutions within the organisation.
  - **External Dependencies:** Execution complexity due to coordination required with third parties and their transition roadmaps (standardisation bodies, vendors, peers, regulators, and customers)

ANTI-PATTERNS

IS QUANTUM CRYPTOGRAPHY A REAL PROBLEM (NOW AND TOMORROW)

Typical self-Question for migration Priority

- **Is urgent action important?** Clarifying the potential business, operational, and reputational impacts of inaction.
- **What is the cost–benefit of acting sooner rather than later?** Evaluating the trade-offs between early adoption and delayed migration, (think to evolving market opportunities and technology readiness).
- **When should we act?** Understanding the priorities based on Quantum Risk exposure and implementation complexity to determine the optimal timing for initiating migration activities.
- **What are our dependencies?** Identifying internal or external supply chain factors that could influence execution timelines.
- **Do we have the required capacity?** Evaluating whether internal expertise and execution capabilities are adequate for our organisation's change roadmap, or if additional support is needed**.**
- **Is our plan effective?** Assessing whether available and planned resources, technologies, and coordination efforts support a timely and successful transition

ANTI-PATTERNS

ASSESSING RISK WITH A QUANTUM RISK SCORE

FACTOR	SCALE (1–3)
SHELF LIFE	1 = <2 years (short-term) 2 = 2–5 years (medium-term) 3 = >5 years (long-term)
EXPOSURE	1 = Data accessed over owned infrastructure only 2 = Data access is limited to specific third parties 3 = Data is publicly accessible or can be easily leaked
SEVERITY	1 = Minimal impact (reputational at most) 2 = Relevant business impact 3 = Severe disruption

- level 1 represents the lowest or least severe risk,
- level 2 represents a moderate or intermediate risk, and
- level 3 represents the highest or most severe risk.

Quantum Risk Score = round (sum of factors ÷ 3)

ANTI-PATTERNS

ASSESSING MIGRATION TIME

- level 1 represents the lowest or least severe risk,
- level 2 represents a moderate or intermediate risk, and
- level 3 represents the highest or most severe risk.

FACTOR	SCALE (1–3)
SOLUTION AVAILABILITY	1 = Available now or <1 year 2 = Expected in 1–3 years 3 = Uncertain or >3 years
EXECUTION COST AND TIME	1 = Minor reconfigurations as part of business as usual (BAU) 2 = Moderate architectural changes 3 = Major, uncertain, or costly upgrades (e.g., logistically complex hardware replacements)
EXTERNAL DEPENDENCIES	1 = Minimal or already widely adopted 2 = Dependent on third parties with known 1 to 3-year roadmaps 3 = Dependent on third parties with uncertain or > 3-year roadmaps

Migration Time Score = round (sum of factors ÷ 3)

ANTI-PATTERNS

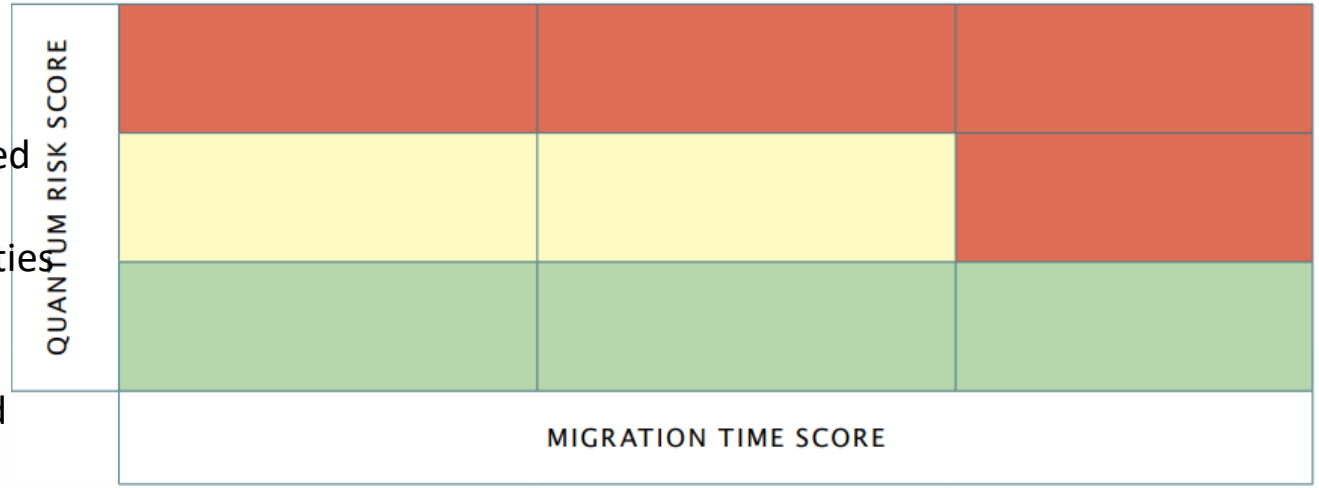
RISK MATRIX

High Priority (Red)

1. **High-risk use cases with readily available solutions**: ‘Low-hanging fruit’ for immediate transition.
2. **High-risk use cases requiring preparation**: Should be included in the roadmap with near-term planning (budget allocation, platform upgrades, prerequisites). No-regret technical activities should be initiated as pre-work for the transition.
3. **High and medium-risk use cases with long dependencies:** Require long-term planning, assessing the critical factors and actions required to ensure timely completion.

Medium Priority (Yellow)

4. **Medium-risk use cases with short migration paths**: May be included in BAU upgrades.
5. **Medium-risk use cases requiring planning:** Should be tracked to determine optimal preparation timelines. No-regret technical activities may be initiated as pre-work for the transition.

Low Priority (Green)

6. **Low-risk use cases**: Can be addressed opportunistically through standard modernisation programmes.